

File No.: EXP202212774

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: Ms. A.A.A. (hereinafter the complainant) filed a complaint with the Spanish Agency for Data Protection on 13/10/2022. The complaint is directed against the TOWN HALL OF MIGJORN GRAN, ES with NIF P0700001A (hereinafter the respondent). The reasons for the complaint are as follows: the complainant states that the respondent has violated the regulations regarding the protection of personal data by sending her a notification; on the outside of the envelope used to notify her of the act, her full ID number appears along with her name, surname, and address, which can be noted by anyone who has seen the envelope or participated in the postal process from the moment it left the respondent until it was delivered to her home.

She provides a photograph of the envelope used to send the notification.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), on 01/12/2022, the complaint was forwarded to the respondent for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on 01/12/2022 as stated in the receipt that is part of the file.

THIRD: On 13/01/2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: On 03/05/2023, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against the respondent for the alleged infringement of Article 32.1 of the GDPR, classified under Article 83.4.a) of the GDPR, in accordance with the provisions of Article 77 of the LOPDGDD.

FIFTH: After notification of the initiation agreement, the respondent submitted a written statement on 22/05/2023, stating the following: that as also noted in the agreement, Article 77 of the LOPDGDD establishes the possibility of resorting to a warning when the processing carried out does not comply with its provisions; that there has been no material damage; the absence of intent, and that appropriate measures have been taken to prevent incidents like the one that occurred and to comply with what is stated in Article 32 of the GDPR.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

SIXTH: On 23/05/2023, a period for the practice of evidence was initiated, agreeing to the following: To consider reproduced for evidentiary purposes the complaint filed by the complainant and its documentation, the documents obtained and generated during the admission phase of the complaint, which are part of the file.

To consider reproduced for evidentiary purposes the allegations to the initiation agreement of the sanctioning procedure, submitted by the respondent and the documentation accompanying them.

SEVENTH: On 10/07/2023, a Proposal for Resolution was issued stating that the Director of the Spanish Agency for Data Protection should sanction the respondent for the infringement of Article 32.1 of the GDPR, classified under Article 83.4.a) of the GDPR, with a warning.

The respondent, on 20/07/2023, submitted a written statement regarding the aforementioned

Proposal, stating that they had demonstrated, through the submission of a report from the Local Police, that appropriate measures had been taken to prevent future incidents.

EIGHTH: From the actions taken in this procedure, the following have been established,

PROVEN FACTS

FIRST. On 13/10/2022, a document from the complainant was received at the AEPD in which they state that the respondent has violated the regulations regarding the protection of personal data by sending her a notification and that on the outside of the envelope used, her full ID number appears along with her name and surname, which can be noted by anyone who has seen the envelope or participated in the postal process from the moment it left the respondent until it was delivered in person at her home.

SECOND. A photograph of the envelope used in the notification is included, which shows the ID number along with the name and surname of the complainant.

LEGAL GROUNDS

I

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/10

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

The reported facts materialize in that the notification received by the complainant considers that the data protection regulations concerning personal data have been violated by sending him the envelope showing on the outside the ID number along with his name, surname, and address.

Article 58 of the GDPR, Powers, states:

"2. Each supervisory authority shall have all of the following corrective powers:

(...)

b) to impose an administrative fine on the controller or processor with a warning when the processing operations have infringed the provisions of this Regulation;

(...)

d) to order the controller or processor to bring processing operations into compliance with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time;

(...)."

III

The possible infringement of Article 32 of the GDPR "Security of processing" is attributed to the respondent, which establishes that:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this Article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law.”

IV

The violation of Article 32 of the GDPR is classified in Article 83.4.a) of the aforementioned GDPR in the following terms:

“4. Infringements of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 2% of the total global annual turnover of the preceding financial year, opting for the higher amount:

- a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43.

(...)”

For its part, the LOPDGDD in its Article 71, Infringements, states that:

“Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

And in its Article 73, for the purposes of prescription, qualifies as “Infringements considered serious”:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a two-year limitation period: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...)”

- g) The breach, as a result of a lack of due diligence, of the technical and organizational measures that should have been implemented in accordance with the requirements of Article 32.1 of Regulation (EU) 2016/679.”

(...)”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/10

V

1. The GDPR defines personal data security breaches as “all breaches of security that result in the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data.”

From the documentation in the file, there is clear evidence that the respondent has violated Article 32 of the GDPR, as a security incident occurred due to the notification carried out by the respondent, with a breach of technical and organizational measures.

It should be noted that the GDPR in the aforementioned provision does not establish a list of security measures applicable according to the data being processed, but rather states that the data controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the risks of likelihood and severity for the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk,

indicating that the determination of technical and organizational measures should be made considering: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification processes (not audits), evaluation, and assessment of the effectiveness of the measures. In any case, when assessing the adequacy of the level of security, particular attention shall be paid to the risks presented by the data processing, as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this same sense, Recital 83 of the GDPR states that:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or processor must assess the inherent risks of the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data, particularly those that could cause physical, material, or immaterial harm.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
6/10

2. In the case analyzed, as stated in the facts and within the framework of the investigation file initiated, the AEPD transferred the complaint presented to the respondent on 01/12/2022 for them to analyze it and inform this Agency of the actions taken to comply with the requirements set forth in the data protection regulations, without receiving a response to the aforementioned request. It is true that in the written allegations dated 22/05/2023, the respondent stated: “Please note that no material damage has occurred, nor is there any intent, and we also inform you that the City Council has taken the necessary measures to comply with Article 32 of the GDPR. Therefore, regarding the indicated facts, appropriate measures have been taken to ensure that no reference to the national identity document appears on the notification envelopes.” However, it is also true that despite the aforementioned statements, the measures adopted to prevent the incident that led to the procedure from occurring again have not been evidenced. The respondent has also claimed the absence of damages and the lack of intent in their actions. Regarding the absence of damages, such an argument is not acceptable given the violation of the fundamental right to the protection of personal data inherent in the infringement committed, and concerning the absence of intent, while it is true that it cannot be asserted in this matter that there was intentional or fraudulent action, it should be noted that intent is not required for its perfection, as it can be committed through simple negligence. The responsibility of the respondent is determined by the security breach highlighted by the complainant, as they are responsible for making decisions aimed at effectively implementing the appropriate technical and organizational measures to ensure a level of security adequate to the risk to guarantee the confidentiality of the data, restoring its availability and preventing access to it in the event of a physical or technical incident. In accordance with the above, it is estimated that the respondent would be presumably responsible for the infringement of the GDPR: the violation of Article 32, an infringement classified in Article 83.4.a).

3. The respondent, in their response to the Proposal for Resolution dated 20/07/2023, claimed to substantiate through the submission of a Local Police Report that appropriate measures had been taken to prevent incidents in the data processing operations and that these complied with the provisions of the Regulation. However, the cited Report does not derive, substantiate, or justify the adoption of the measures referred to by the respondent; it merely states that the Local Police Headquarters informs of the following aspects: “Notify the adoption by this City Council of the

appropriate and necessary measures to rectify the error committed, with the notification method currently corrected to avoid...

7/10

that in the future incidents occur similar to those that have led to the opening of the present sanctioning procedure to avoid security incidents;

VI

The LOPDGDD in its article 77, Applicable regime to certain categories of controllers or processors, establishes the following:

“1. The regime established in this article shall apply to the processing for which the following are responsible or act as processors:

- a) The constitutional bodies or those with constitutional relevance and the institutions of the autonomous communities analogous to them.
- b) The judicial bodies.
- c) The General Administration of the State, the administrations of the autonomous communities, and the entities that comprise the Local Administration.
- d) The public bodies and entities of public law linked to or dependent on the Public Administrations.
- e) The independent administrative authorities.
- f) The Bank of Spain.
- g) The public law corporations when the purposes of the processing relate to the exercise of public law powers.
- h) The public sector foundations.
- i) The Public Universities.
- j) The consortiums.
- k) The parliamentary groups of the General Courts and the legislative assemblies of the autonomous communities, as well as the political groups of the Local Corporations.

2. When the controllers or processors listed in section 1 commit any of the infringements referred to in articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or correct the effects of the infringement that has been committed. The resolution shall be notified to the controller or processor, to the body to which it is hierarchically dependent, if applicable, and to the affected parties who had the status of interested parties, if applicable.

3. Without prejudice to what is established in the previous section, the data protection authority shall also propose the initiation of disciplinary actions when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regime that is applicable.

Likewise, when the infringements are attributable to authorities and executives, and the existence of technical reports or recommendations for processing that have not been duly addressed is accredited, the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order the publication in the Official State Bulletin or the corresponding autonomous bulletin.

4. The resolutions related to the measures and actions referred to in the previous sections must be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article shall be communicated to the Ombudsman or, where appropriate, to the analogous institutions of the autonomous communities.

6. When the competent authority is the Spanish Agency for Data Protection, it shall publish on its website, with due separation, the resolutions referred to the entities in section 1 of this article, with express indication of the identity of the controller or processor who has committed the infringement. When the competence corresponds to an autonomous data protection authority, the publicity of these resolutions shall be governed by its specific regulations.”

In the present sanctioning procedure, the respondent has violated the regulations on the protection of personal data by infringing the technical and organizational measures implemented; in the analyzed case, the respondent sent a notification and on the outside of the envelope used appeared the complete ID number of the complainant along with their name, surname, and address, allowing a third

party who has seen the envelope or participated in the postal process from the moment it left the respondent until it was delivered by hand at their home to take note of it.

In accordance with the evidence available, this conduct constitutes, on the part of the respondent, the infringement of what is established in article 32.1 of the GDPR.

However, it should be noted that the GDPR, without prejudice to what is established in its article 83, contemplates in its article 77 the possibility of resorting to the sanction of warning to correct the processing of personal data that does not comply with its provisions, when the controllers or processors listed in section 1 commit any of the infringements referred to in articles 72 to 74 of this organic law.

In this same sense, article 58 of the GDPR provides, in its section 2 d), that each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified period...”.

VII

Having confirmed the infringement, it is appropriate to impose on the responsible party the adoption of adequate measures to adjust their actions to the regulations mentioned in this act, in accordance with what is established in the aforementioned article 58.2 d) of the GDPR,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/10

according to which each supervisory authority may “d) order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame.”

In the present case, the respondent is required to, within one month from the notification of this Resolution:

- Provide evidence of the adoption of appropriate measures to prevent future incidents similar to those that have led to the initiation of this sanctioning procedure, avoiding security incidents such as the one indicated when sending the notification, where the complete DNI number of the complainant appeared on the outside of the envelope used, along with their name, surname, and address, allowing third parties to take note of it.

It is warned that failure to comply with the possible order to adopt measures imposed by this body in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its articles 83.5 and 83.6, and such conduct may lead to the initiation of further administrative sanctioning procedures.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions whose existence has been established,

The Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on the TOWN HALL OF MIGJORN GRAN, ES, with NIF P0700001A, a warning sanction for an infringement of article 32.1 of the GDPR, classified under article 83.4.a) of the GDPR.

SECOND: TO NOTIFY this resolution to the TOWN HALL OF MIGJORN GRAN, ES.

THIRD: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of article 77.5 of the LOPDGDD.

FOURTH: TO ORDER the TOWN HALL OF MIGJORN GRAN, ES, with NIF P0700001A, that pursuant to article 58.2.d) of the GDPR, within one month from this Resolution, provide evidence of having adopted appropriate measures to prevent events such as those that led to the sanctioning procedure: violation of technical and organizational measures, article 32.1 of the GDPR, and that the processing carried out complies with the provisions of this Regulation.

In accordance with the provisions of article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with art. 48.6 of the LOPDGDD, and in accordance with the provisions of article 123 of the

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es

10/10

LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of art. 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation evidencing the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

Mar España Martí
Director of the Spanish Agency for Data Protection
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es